

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

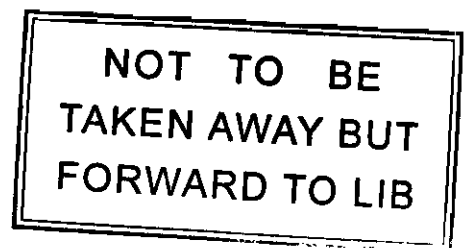
Session : Semester A 2007/08

Time allowed : Two hours

This paper has SEVEN pages (including this cover page).

1. This paper consists of 10 questions.
 2. Answer ALL TEN questions.
 3. Total: 100 points
 4. This is a close-book examination: students should not bring any books, lecture or tutorial notes; problem set solutions or any other related papers or printouts
 5. Calculators: only HKEA approved ones
-

NOT TO BE TAKEN AWAY



Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. Block Cipher (10 points)

The formula for counter (CTR) mode encryption is

$$C_i = P_i \oplus E(IV + i, K).$$

Suppose we modify it and use the following formula instead.

$$C_i = P_i \oplus E(K, IV + i)$$

(a) (4 points)

Is this secure and why or why not?

(b) (2 points)

How many bits are in the keys of DES and AES, respectively?

(c) (2 points)

How many bits are in a plaintext block for DES and AES, respectively?

(d) (2 points)

How many bits are in each subkey and how many S-boxes are in DES?

2. Operation Modes (10 points)

Suppose you have a file encrypted using AES in CBC mode. There are 100 blocks of ciphertext created.

(a) (3 points)

Suppose you want to decrypt the 50th ciphertext block. How many blocks of ciphertext do you actually need to decrypt? Which blocks of ciphertext are they?

(b) (3 points)

Suppose you want to modify the 50th ciphertext block. How many blocks of ciphertext do you need to re-encrypt? Which blocks are they?

(c) (2 points)

Suppose the same file is encrypted using AES in CTR mode. You want to modify the 50th ciphertext block. How many blocks of ciphertext do you actually need to decrypt? Which blocks of ciphertext are they?

(d) (2 points)

Give one advantage and one disadvantage of using AES in ECB mode when compared with CTR mode.

3. RSA (10 points)

(a) (2 points)

In RSA, a common encryption exponent of $e = 3$ is commonly used. What is the advantage of this in practice?

(b) (2 points)

Would it be a good idea to use $d = 3$ as a common decryption exponent?

(c) (6 points)

Suppose the two RSA primes p and q are 13 and 17, respectively. Suggest an encryption exponent e and the corresponding decryption exponent d for this RSA system.

4. ECC (10 points)

Consider an elliptic curve defined by $E: y^2 = x^3 + x \pmod{23}$.

(a) (2 points)

Let $P = (9, 5)$ be a point on curve E . Find $-P$. In your answer, both x and y coordinates should be positive integers.

(b) (3 points)

Let $P = (16, 8)$ and $Q = (16, 15)$. Compute $P + Q$.

(c) (5 points)

Find any four points on the curve E .

5. GSM (10 points)

(a) (4 points)

Give any four security flaws that the current GSM security systems suffer from.

(b) (6 points)

Consider the GSM security protocol below. Modify this protocol so that it achieves mutual authentication.

Protocol Steps:

1. $M \rightarrow BS$: IMSI
2. $BS \rightarrow AuC$: IMSI
3. $BS \leftarrow AuC$: RAND, XRES, K_c
4. $M \leftarrow BS$: RAND
5. $M \rightarrow BS$: SRES

Notations: M: mobile; BS: base station; AuC: authentication centre

In your protocol description, specify the bit length of each new parameter introduced.

6. SSL and IPSec (10 points)

(a) (2 points)

Explain why the SSL protocol cannot allow the server (namely, Bob) to remain anonymous against eavesdroppers.

(b) (4 points)

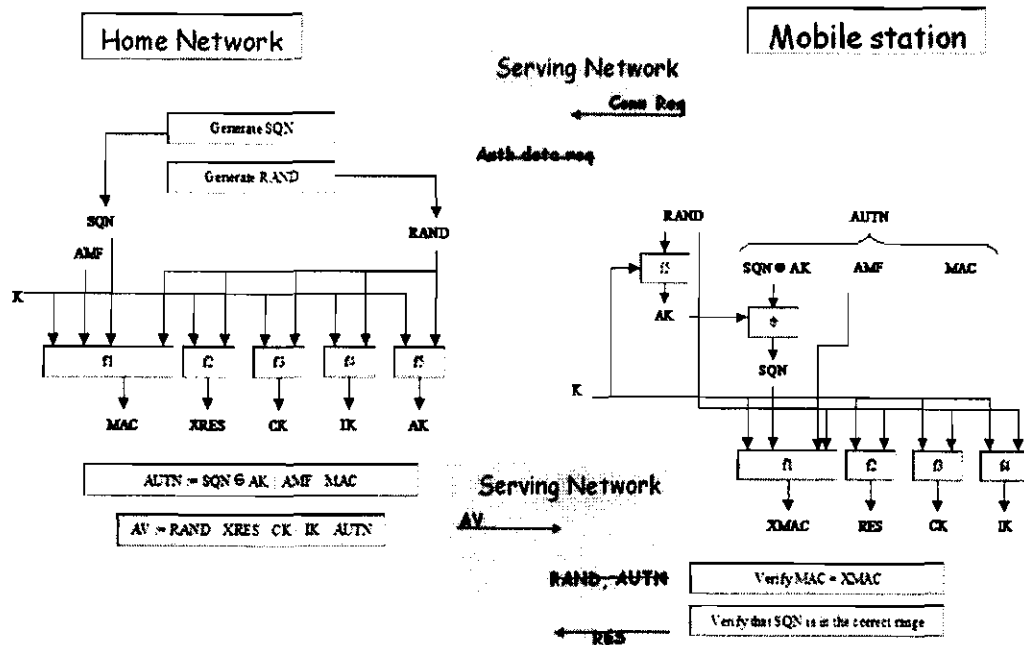
Modify the protocol so that Bob can remain anonymous. Hint: The IPSec main mode public key protocols allow the users to remain anonymous.

(c) (4 points)

Suppose host A has an IP address 1.1.1.1 and host B has an IP address 2.2.2.2. If A sends an IPSec datagram to B using tunnel mode, what are the source and destination addresses of the inner as well as the outer IP headers?

7. 3GPP (10 points)

Consider the following authentication and key agreement protocol for 3GPP, which is from the lecture notes.



- (3 points)
Authentication key AK is computed as $AK \leftarrow f_5(K, RAND)$. If the algorithm is changed to $AK \leftarrow f_5(K)$, what security flaw will be introduced and why?
- (3 points)
If we modify the computation of the encryption key CK such that $CK \leftarrow f_3(K, RAND, SQN)$, give one disadvantage of this modification when compared with the original design.
- (2 points)
For simplifying the design, a software developer makes f_3 and f_5 identical so that the total number of functions that need to be implemented is reduced. Describe one security flaw in this modification.
- (2 points)
If f_2 is identical to f_4 , is there any security flaw and why or why not?

8. Hash Function (10 points)

(a) (2 points)

Let h be a hash function whose output is N bits long. What is the expected number of random values that need to be tried in order to find a collision?

(b) (2 points)

Suppose $h(M) = g^M \bmod p$, where p is a large prime and g is some appropriate positive integer. Based on what number theoretic assumption is this hash function one-way?

(c) (2 points)

What is weak collision resistant and what is strong collision resistant?

(d) (4 points)

Suppose $h(M) = g^M \bmod p$, where p is a large prime and g is some appropriate positive integer. Give an example to show that it does not satisfy weak collision resistant.

9. Access Control (10 points)

(a) (3 points)

What are the three ways of authenticating a human to a machine?

(b) (2 points)

In a password file, usually, a pair (s, y) is stored for each user entry where s is a random string and $y = h(\text{password}, s)$ where h is a secure hash function. Why this method is better than simply storing $h(\text{password})$ in the password file?

(c) (5 points)

What is two-factor authentication? Give three examples. For each example, two authentication factors have to be given. Among all these examples, all the factors should be distinct. That is, no reuse of factors between any two examples.

10. Firewall (10 points)

(a) (2 points)

Give one advantage and one disadvantage of packet filter when compared with application proxy.

(b) (2 points)

Among the three firewall techniques: packet filter; stateful packet filter; and application proxy, identify which technique(s) can prevent TCP ACK scan.

(c) (6 points)

Compose an Access Control List (ACL) for a packet filter so that the filter only allows SSL (port no. 443) traffic passing through the filter. Assume that there is no SSL server in the internal network protected by the packet filter. Note: in your answer, you should specify values for the following columns: Action, Source IP, Dest IP, Source Port, Dest Port, Protocol and Flag Bits. Hint: Three rows should be enough for this ACL.

- End -